





Identification, Authentication, and Authorization

Module Objectives



01 Understanding the Terminology, Principles, and Types of Access Control

02 Overview of Identity and Access Management (IAM)

03 Understanding the User Access Management

04 Understanding the Different Types of Authentication

05 Understanding the Different Types of Authorization

06 Understanding the User Accounting

Module Flow

**Discuss Access Control Principles,
Terminologies, and Models**



01



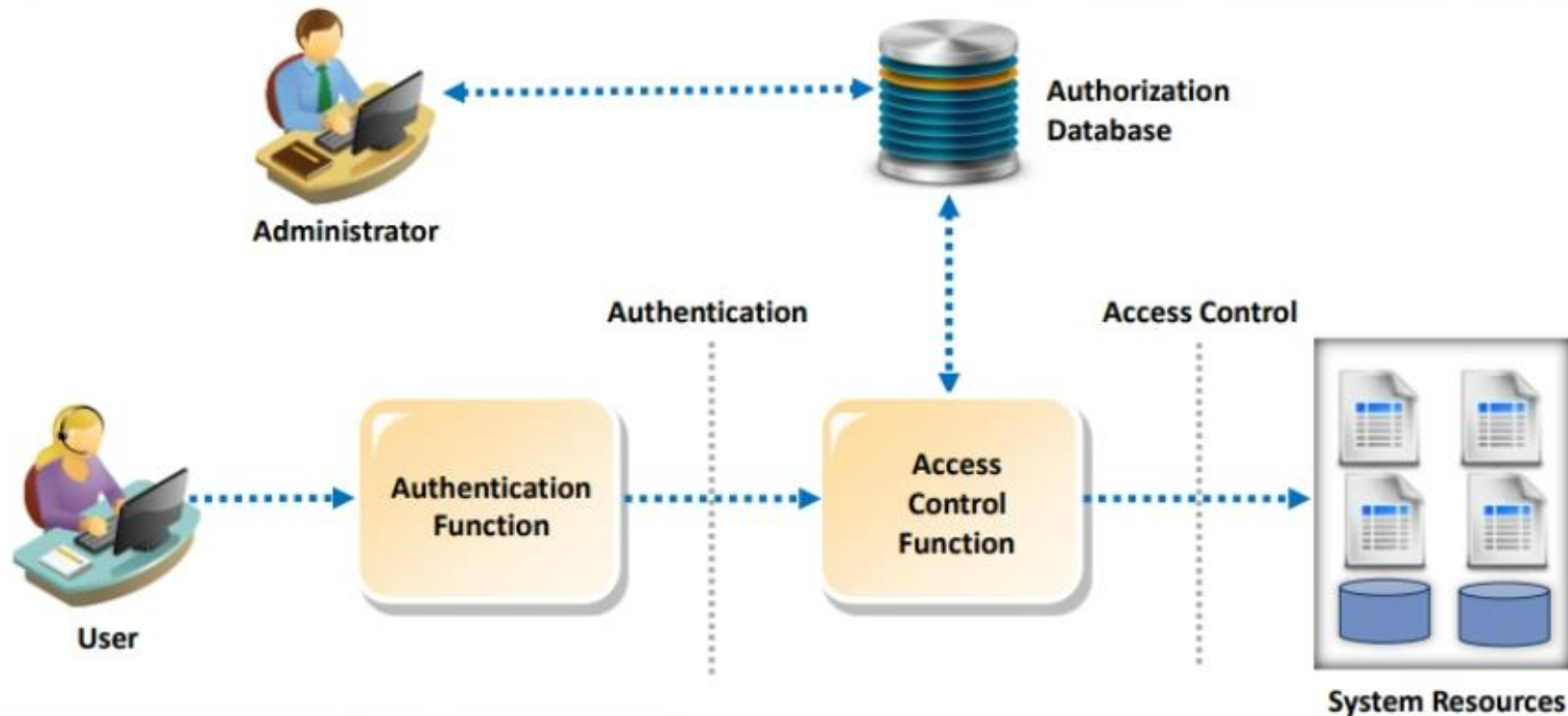
02



**Discuss Identity and Access
Management (IAM)**

Access Control

- ❑ Access control is the **selective restriction** of access to an asset or a system/network resource
- ❑ It **protects the information assets** by determining who can access what
- ❑ Access control mechanism uses **user identification**, **authentication**, and **authorization** to restrict or grant access to a specific asset/resource



Access Control Terminologies

Subject

This refers to a **particular user** or **process** that wants to access a resource

Object

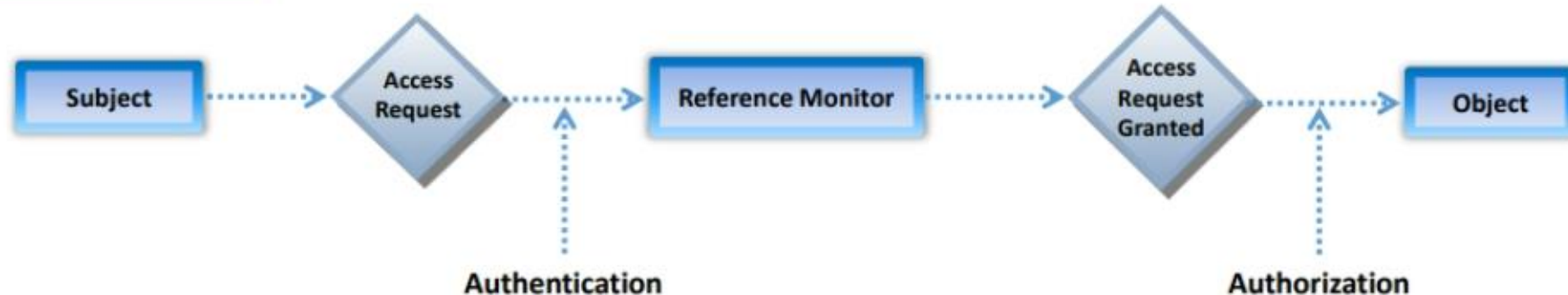
This refers to a **specific resource** that the user wants to access such as a file or a hardware device

Reference Monitor

It checks the **access control rule** for specific restrictions

Operation

It represents an **action** taken by a subject on an object



Access Control Principles

Separation of Duties (SoD)

- Involves a breakdown of the authorization process into various steps
- Different privileges are assigned at each step to the **individual subjects** requesting for a resource
- This ensures that no single individual has the authorization rights to perform all functions and simultaneously **denies access** of all the objects to a single individual



Need-to-know

- Under the need-to-know access control principle, access is provided only to the **information** that is required for performing a specific task



Principle of Least Privilege (POLP)

- Principle of least privilege extends the **need-to-know** principle in providing access to a system
- POLP believes in providing employees a need-to-know access, i.e., not more, not less;
- It helps an organization by protecting it from malicious behavior, achieving better **system stability**, and system security



Access Control Models

- ❑ Access control models are the **standards which provide a predefined framework** for implementing the necessary level of access control



Mandatory Access Control (MAC)

- ✓ Only the administrator/system owner has the rights to assign privileges
- ✓ It does not permit the end user **to decide who can access the information**



Discretionary Access Control (DAC)

- ✓ End user has complete access to the information they own



Role-based Access Control (RBAC)

- ✓ Permission are assigned based on user roles



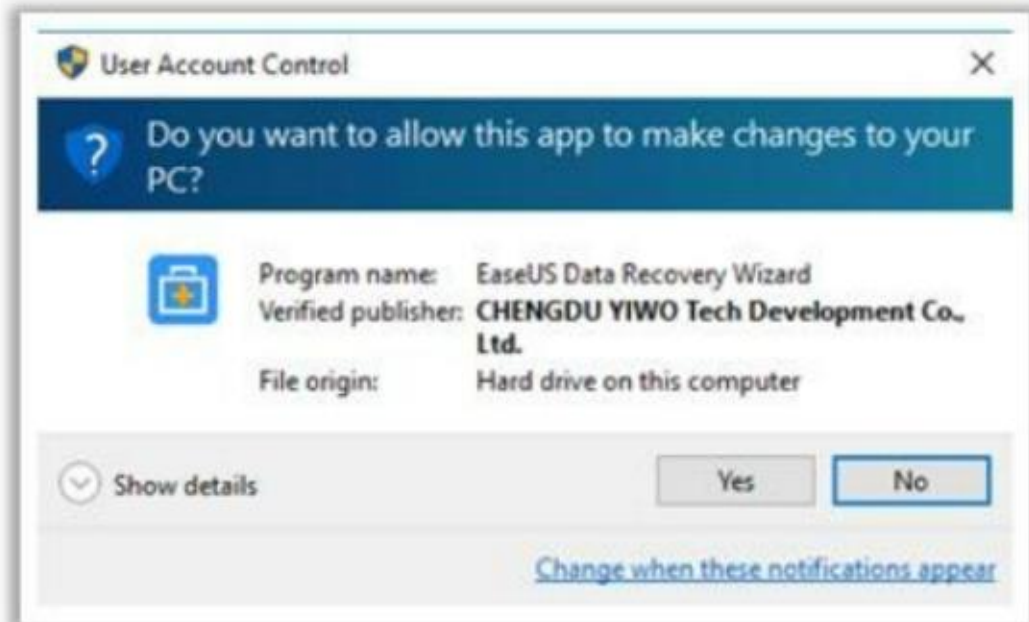
Rule-based Access Control (RB-RBAC)

- ✓ Permissions are assigned to a user role dynamically based on a set of rules defined by the administrator

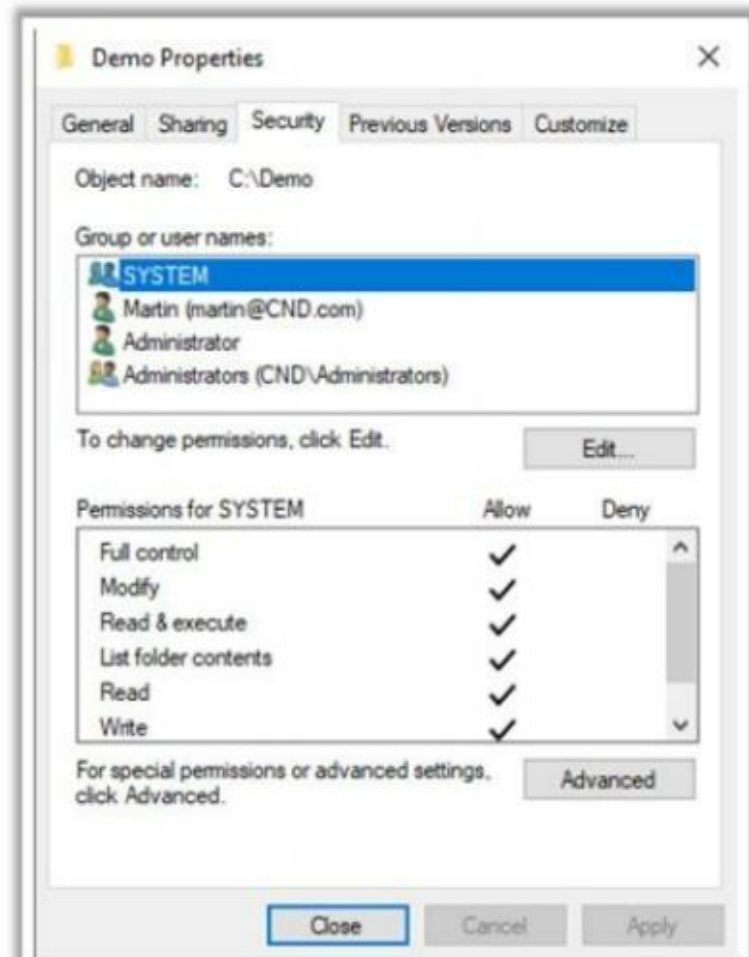
Logical Implementation of DAC, MAC, and RBAC

- ❑ Logical implementation of access control is performed using **access control lists (ACLs)**, **group policies**, **passwords**, and **account restrictions**

MAC Implementation: The User Account Control (UAC) tool of Windows OS



DAC Implementation: Windows File Permissions



Module Flow

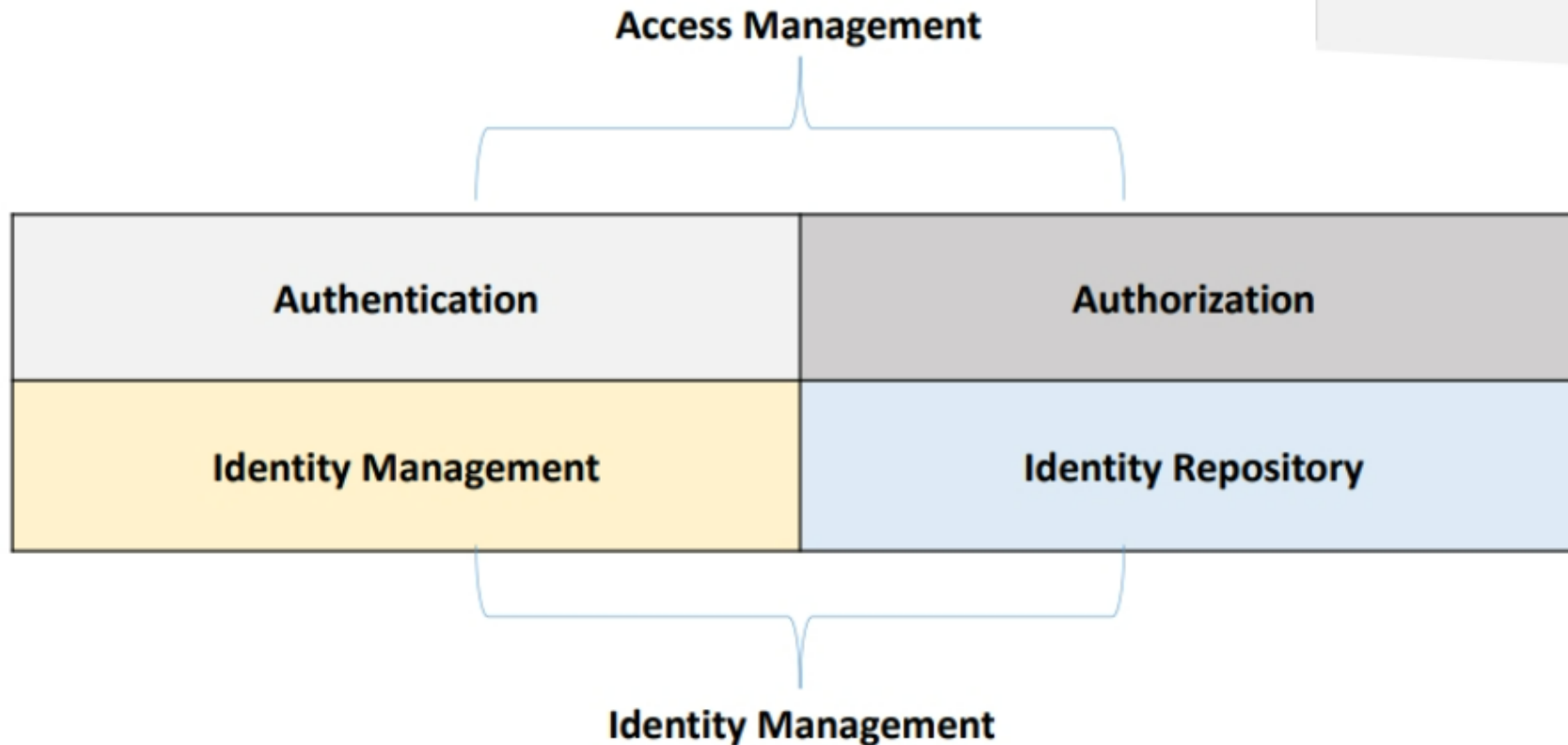
**Discuss Access Control Principles,
Terminologies, and Models**



**Discuss Identity and Access
Management (IAM)**

Identity and Access Management (IAM)

- ❑ IAM is responsible for providing the **right individual with right access at the right time**



Identity



- ❑ Identity refers to a **set of attributes** linked to an entity that can be stored and **authenticated digitally**

User Identification



Identity Provider

1 Verifies user identity

Creates a new account with UID: 2001 & Pwd: \$\$\$

2



User



User Identity Management (IDM)

Identity Management

- ✓ User Identification involves a method to ensure that an **individual holds a valid identity**
- ✓ Examples of user identity includes attributes such as a **username, account number**, user roles, etc.
- ✓ Identity Management involves storing and managing **user attributes** in their repositories

Identity Repository

- ✓ The user repository is a database where attributes related to the **users' identities** are stored



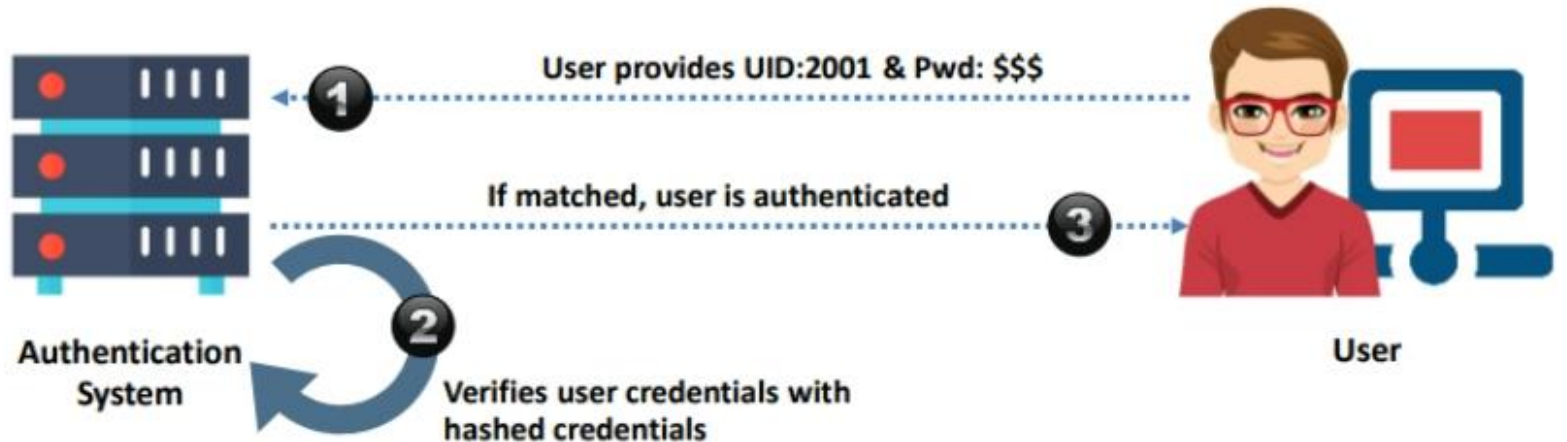
User Access Management (AM)

- ❑ User access management (AM) is the process of **identifying**, **monitoring**, and **regulating** authorized users' access to an IT system, application, or resource
- ❑ It includes all the **policies**, **processes**, **methodologies**, and **tools** required for the maintenance of AM with IT infrastructure
- ❑ Identity management **creates** and **controls** various users, roles, groups, and policies
- ❑ AM **monitors** and **ensures** that all the defined roles and policies are followed



User Access Management (AM): User Authentication

- ❑ Authentication involves **validating the identity** of an individual with a system, application, or network



Types of Authentication: Password Authentication

- ☐ Password Authentication uses a **combination** of a username and a password to authenticate the network users
- ☐ The password is checked against a **database** and the user is given access if it matches
- ☐ Password authentication can be vulnerable to **password cracking attacks** such as brute force or dictionary attacks



Types of Authentication: Two-factor Authentication

- 1** Two-factor authentication involves using two different authentication factors out of three (something you know, something your have, and something you are) to verify the **identity of an individual** in order to enhance the **security in authentication systems**
- 2** **Combinations of two-factor authentication:** password and smart card/token, password and biometrics, password and one-time password (OTP), smart card/token and biometrics, etc.
- 3** “Something you are” is the best companion of two-factor authentication as it is considered as the **hardest to forge** or **spoof**

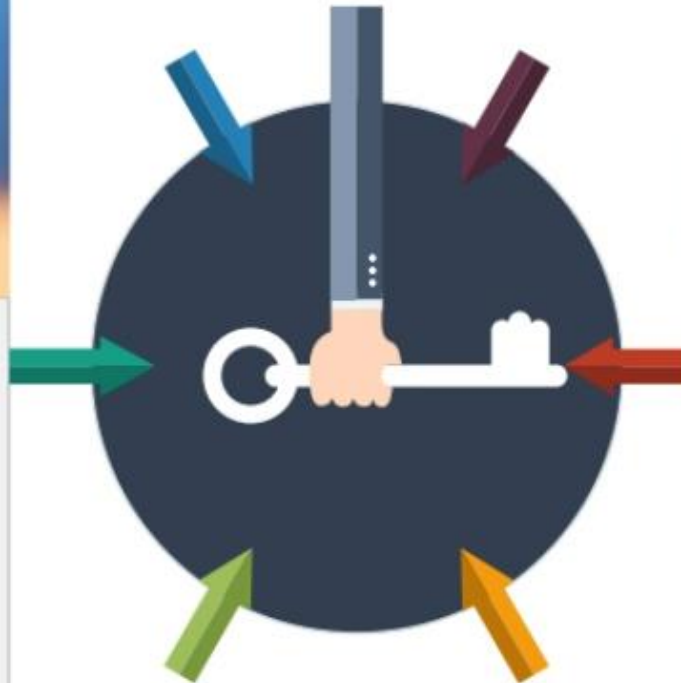


Two-factor Authentication Techniques: Tokens



Hardware Tokens

- ☐ Physical devices such as a key fob or USB dongle having an **in-built token**; used as an authentication factor for accessing any type of restricted resources
- ☐ Valid only for a short period of **approximately 30 seconds**



Software Tokens

- ☐ A software-based security token includes a **single-use login PIN** or dynamically generated token



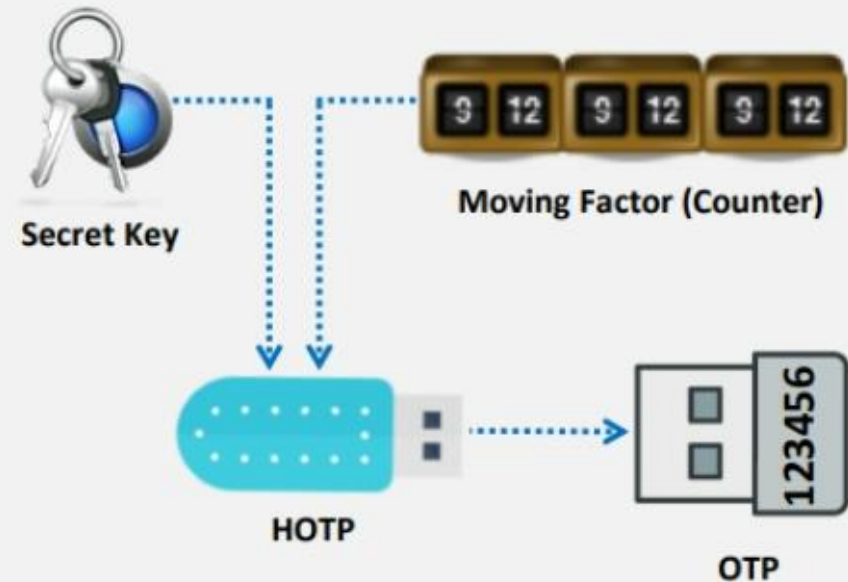
Two-factor Authentication Techniques: OATH



- ❑ Open Authentication (OATH) is a reference architecture designed by a group of companies with the aim of developing an **open strong authentication technology** that supports a wide variety of networks
- ❑ Its main goal is to provide safe and **secure online transactions** for users based on two-factor authentication
- ❑ It has introduced three algorithms, namely, **HOTP**, **OCRA**, and **TOTP**, for implementing OTP authentication

HMAC-based One-time Password (HOTP)

- ✓ An HOTP is an **event-based OTP**, where the input seed is static, and the moving factor is based on a counter
- ✓ When an HOTP is requested, the **moving factor** is incremented based on a counter



Types of Authentication: Biometric Authentication

- ❑ Biometrics refers to the **identification of individuals** based on their physical characteristics

Biometric Identification Techniques

Fingerprint Scanning

Compares two fingerprints for verification and identification on the basis of the **patterns on the finger**

Iris Scanning

Analyzes the **colored part of the eye** suspended behind the cornea



Retinal Scanning

Analyzes the **layer of blood vessels** at the back of their eyes to identify a person

Vein Structure Recognition

Analyzes thickness and **location of veins** to identify a person

Types of Authentication: Biometric Authentication (Cont'd)

Biometric Identification Techniques



Face Recognition

Uses **facial features** to identify or verify a person



Voice Recognition

Uses voice patterns to identify or **verify a person**



Gait analysis

Uses **patterns of locomotion** exhibited by moving limbs while walking or running are different among different individuals

Types of Authentication: Biometric Authentication (Cont'd)

Performance Metrics of Biometric Systems

Efficacy Rates	Depends on technical components, devices used to capture samples, algorithms used to compare with references, and the environment in which the biometric sensor operates
False Acceptance Rate (FAR)	Percentage of identification occurrences in which an unauthorized user gains access to the resources
False Rejection Rate (FRR)	Percentage of identification occurrences in which an authorized user is denied access to the resources
Crossover Error Rate (CER)	The value of the false rejection rate and false acceptance rate when sensitivity is configured such that FRR and FAR are equal
Receiver Operating Characteristic	Visual characterization plot of the trade-off between FAR and FRR
Matching Speed	Time taken to authenticate an individual
Failure To Capture (FTC)	Ratio of the number of times the system does not capture the samples presented to it to the total number of samples presented
Failure to Enroll (FTE)	Ratio of the number of users that are not enrolled in the system to the total number of users presented to the system
Throughput	Total time taken to enroll the biometric of a user and authenticate the user



Types of Authentication: Smart Card Authentication



Smart card is a small **computer chip device** that holds a users' personal information required to authenticate them



Users have to insert their smart cards into the card reader machines and enter their **personal identification number** (PIN) to authenticate themselves



Smart card authentication is a **cryptography-based authentication** and provides stronger security than password authentication

Types of Authentication: Single Sign-on (SSO) Authentication



- It allows a user to authenticate themselves to **multiple servers** on a network with a **single password** without re-entering it every time

Advantages

01

No need to remember passwords of multiple applications or systems

02

Reduces the time for entering a username and password

03

Reduces the network traffic to the **centralized server**

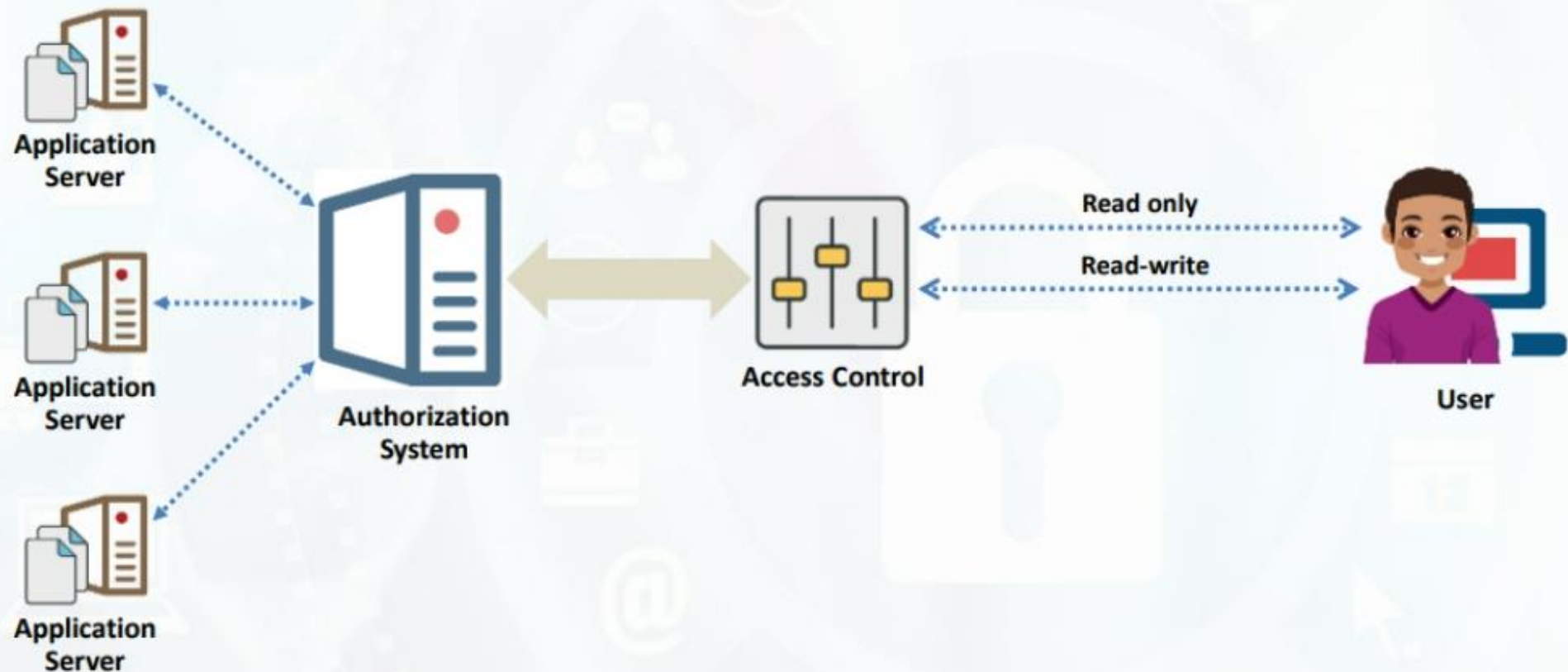
04

Users need to enter credentials only once for multiple applications



User Access Management (AM): Authorization

- ❖ Authorization involves **controlling the access** of information for an individual (E.g.: A user can only read a file, but not write in it or delete it)

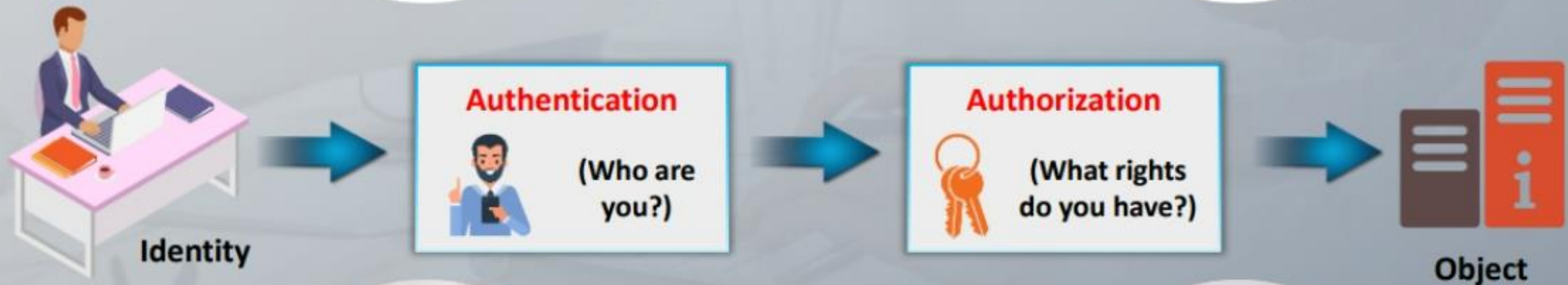


User Access Management (AM): Accounting



- ❑ Accounting is a method of keeping **track** of **user actions** on the network. It keeps track of who, when, and how the users access the network
- ❑ It helps in identifying **authorized** and unauthorized actions
- ❑ The account data can be used for **trend analysis**, data breach detection, **forensics investigations**, etc.

Accountability



Account Types



User Accounts

- Default accounts of operating systems
- Run with the **least privileges**, with permissions such as running applications/programs and creating and manipulating files



Guest Accounts

- Least privileged accounts without passwords, created to **share system resources**
- Do not have any privileges to modify system files, directories, or settings



Service Accounts

- Domain or local accounts that allow applications or **services to communicate** with the operating system and run programs
- Has administrative privileges based on the application requirement



Administrator/Root Accounts

- Privileged accounts that can perform various **system-level functions** such as install and uninstall applications or system software and modify system-level settings



Privileged Accounts

- Have administrative control over one or several systems
- Permitted to **access any resources** in the system, configure drivers, add/discard applications from service, etc.

Module Summary



- ❑ This module discussed the terminology, principles, and types of access control
- ❑ It covered identity and access management (IAM)
- ❑ It also discussed user access management
- ❑ Furthermore, this module discussed the different types of authentication and authorization
- ❑ Finally, this module presented an overview of user accounting
- ❑ The next module discusses administrative network security controls in detail



Thank you!